



ISMS SOPE DOCUMENT

Confidential

G-R-C Ops

Classification: **Confidential**

This document may only be shared internally without prior confirmation from the owner.

Version	Approved By	Owner	Date Last Updated	Review Frequency	Next Review	Comments
1.0	Board of Directors	CISO	-	Monthly	23th – February - 2026	

Contents

Purpose of Document.....2

Scope Statement.....2

Context of the Organisation2

 Internal Issues2

 Organisational Structure2

 Business Processes3

Interested Internal Stakeholders3

External Issues3

 Legal & Regulatory Obligations.....3

Technical Environment3

Scope of the Information Security Management System.....3

 Business Functions within Scope.....3

 Physical Locations within Scope4

 Technology Services within Scope4

 Outsourced Services within Scope4

Risk Assessment & Treatment.....4

Key Policies & Procedures.....4

Purpose of Document

This document formally defines the scope of the Information Security Management System (ISMS) of Saudi EXIM Bank in accordance with ISO/IEC 27001:2022 Clause 4.3. It establishes the organizational, physical, technological, and operational boundaries of the ISMS and ensures alignment with regulatory, contractual, and business requirements.

Scope Statement

The Information Security Management System (ISMS) of Saudi EXIM Bank applies to the protection of information assets, systems, processes, and personnel supporting the Bank's export financing, credit facilities, trade finance operations, and corporate support functions.

The ISMS covers all information processed, stored, or transmitted by Saudi EXIM Bank, including customer financial data, transactional records, employee data, operational data, regulatory reporting information, and third-party shared information.

The scope includes:

- All business units and support departments
- All physical locations operated by the Bank within the Kingdom of Saudi Arabia
- All on-premises and cloud-hosted systems
- All network infrastructure and endpoints
- All third-party services that process or access Bank information

This ISMS is established in accordance with ISO/IEC 27001:2022 and aligned with applicable regulatory and contractual obligations.

Context of the Organisation

Internal Issues

- Rapid digital transformation in banking services
- Increasing cyber threats targeting financial institutions
- Expansion of remote access and hybrid working
- Dependence on third-party technology providers
- Requirement to implement a hybrid SOC

Organisational Structure

The ISMS applies to:

- Board of Directors
- Executive Management
- CISO
- Information Security Management
- IT / Security Operations
- Risk Management
- Internal Audit
- Finance
- HR
- Operations / Trade Finance
- Vendor Management
- All employees and contractors

Business Processes

- Export financing approval and processing
- Trade credit issuance
- Customer on boarding and KYC
- Financial transaction processing
- Regulatory reporting
- Vendor on boarding and management
- IT service delivery and infrastructure management

All processes rely on secure handling of financial and customer data.

Interested Internal Stakeholders

Stakeholder	Security Requirements
Board of Directors	Risk visibility, regulatory compliance, protection of reputation
Executive Management	Business continuity, risk control, regulatory alignment
IT & Security	Clear policies, defined controls, risk prioritization
HR	Protection of employee data, awareness training
Finance	Financial integrity, fraud prevention
Operations	System availability and integrity
All Staff	Clear policies, secure systems

External Issues

Legal & Regulatory Obligations

- Saudi Central Bank (SAMA) cybersecurity framework
- National Cybersecurity Authority (NCA) ECC
- Saudi Personal Data Protection Law (PDPL)
- PCI DSS (if cardholder data is processed)
- Contractual security requirements with partners

Technical Environment

The Bank operates:

- Core banking and trade finance platforms
- Secure internal network infrastructure
- Firewalls, IDS/IPS
- MFA implementation for critical systems
- Hybrid SOC model
- Endpoint Detection & Response (EDR)
- Vulnerability scanning tools
- Backup and disaster recovery infrastructure
- Secure remote access via VPN

Scope of the Information Security Management System

Business Functions within Scope

Area	Information Assets	Reason for Inclusion
Finance	Financial statements, payroll, reporting	Regulatory and financial integrity
IT	Infrastructure, logs, backups	Core security control layer
Operations	Trade finance records, customer transactions	Core business function

HR	Employee records	Personal data protection
Risk & Compliance	Risk register, audit reports	Governance requirement

Physical Locations within Scope

Location	Description
Headquarters (KSA)	Primary operational facility
Disaster Recovery Site	Business continuity support
Remote Work Environments	Secure remote access to systems

Technology Services within Scope

Asset	Description
Core Banking System	Financial processing
Email System	Internal and external communications
Endpoint Devices	Staff laptops and desktops
Network Infrastructure	Routing and firewall systems
Backup Systems	Data recovery and retention
SOC Platform	Monitoring and detection

Outsourced Services within Scope

Area	Description
Managed SOC	Security monitoring services
Cloud Providers	Hosting services (if applicable)
External Auditors	Compliance validation
Critical Vendors	Processing or storing Bank data

Risk Assessment & Treatment

Risk assessment follows ISO 27005-aligned methodology using:

- Asset identification
- Threat and vulnerability analysis
- Likelihood × Impact scoring
- Risk register documentation
- Risk treatment planning
- Statement of Applicability (SoA)

Risk acceptance requires management approval consistent with defined risk appetite.

Key Policies & Procedures

Policy / Procedure Name	Purpose
Information Security Policy	An overarching policy that defines the Bank's strategic direction for information security, establishes governance principles, and provides reference to all supporting security policies and standards.
Risk Management Policy	A policy that establishes the framework for identifying, assessing, evaluating, and treating information security risks in alignment with the Bank's risk appetite and regulatory obligations.
Access Control Policy	A policy that defines the principles and requirements for granting, managing, reviewing, and revoking access to information systems to ensure authorized access and enforce least privilege.

Incident Response Policy	A policy that establishes the structured approach for detecting, reporting, responding to, and recovering from information security incidents to minimize operational and regulatory impact.
Business Continuity Policy	A policy that defines the framework for maintaining and restoring critical business operations during disruptions to ensure service continuity and resilience.
Vendor Security Policy	A policy that outlines the requirements for assessing, on boarding, monitoring, and managing third-party vendors to ensure protection of information assets throughout the supply chain.
Acceptable Use Policy	A policy that defines the acceptable and prohibited use of the Bank's information systems, networks, and assets to ensure secure and responsible behaviour by users.
Data Classification Policy	A policy that establishes the framework for classifying information assets based on sensitivity and criticality to ensure appropriate handling, storage, transmission, and disposal controls.
Backup & Recovery Policy	A policy that defines the requirements for data backup, retention, testing, and restoration to ensure availability and integrity of information in the event of system failure or data loss.